

Installation sécuritaire d'un Système d'exploitation

Stéphane Gill

Stephane.Gill@CollegeAhuntsic.qc.ca

Table des matières

Introduction.....	3
Le rôle de l'ordinateur.....	3
Le choix d'une distribution.....	3
L'installation.....	4
Étape 1 : Installation depuis la source.....	4
Étape 2 : Définition de partitions multiples.....	5
Étape 3 : Installation et activation de l'essentiel uniquement.....	6
Étape 4 : Réorganisation des systèmes de fichiers.....	6
Étape 5 : Installation des mises à jour.....	7
Bastille Unix.....	7
Installation (à vérifier).....	8
Démarrage.....	8
Installation sécuritaire d'un serveur Windows.....	9
Mot de passe de l'administrateur.....	9
Désactiver les services qui ne sont pas utiles.....	10
Désactiver ou supprimer tout les comptes qui ne sont pas essentiel.....	10
Protéger les fichiers et les répertoires.....	10
Assurez vous que le compte invité est bien désactivé.....	10
Cacher une machine du réseau.....	10
Désactiver tout les partages de fichiers inutiles.....	10
Installer un logiciel anti-virus:.....	11
Installez les services packs.....	11
Références.....	11

Document écrit par Stéphane Gill

© Copyright 2013 Stéphane Gill

Ce document est soumis à la licence GNU FDL. Permission vous est donnée de distribuer et/ou modifier des copies de ce document tant que cette note apparaît clairement.

Introduction

Dans ce document, les principales étapes d'une installation sécuritaire de Linux ainsi que le processus de choix d'une distribution sont présentés. Finalement, les grandes lignes de l'installation d'un serveur Windows sont expliquées.

Le rôle de l'ordinateur

L'identification du rôle de l'ordinateur permet de faciliter le choix de la distribution de Linux et le choix des paquetages lors de l'installation. Les ordinateurs d'un réseau supportent généralement un des 4 rôles suivants :

- Poste de travail;
- Serveur;
- Infrastructure;
- Universel.

Le choix d'une distribution

Le processus du choix d'une distribution Linux pour une installation sécurisée implique d'abord que le rôle de l'ordinateur soit identifié. Par la suite, un compromis entre les fonctionnalités nécessaires et la sécurité doit être trouvé. Voici quelques règles :

- Les postes de travail ont besoin de fonctionnalités;
- Les serveurs et les infrastructures ont besoin de sécurité et de stabilité.

Les principales distributions à considérer pour une installation de Linux sont :

- RedHat/CentOS;
- Mageia;
- Mint Linux

- Ubuntu;
- Debian.

Mint Linux, Mageia et Ubuntu sont d'excellentes distributions à la fine pointe de la technologie et offrant beaucoup de fonctionnalités. Malheureusement, les versions « point-zéro » de ces distributions sont généralement truffées de bogues et de failles de sécurité. Pour les utiliser comme système d'exploitation pour un serveur il faut installer les versions « point-un », « point-deux », ... Ces distributions ne sont généralement pas sûres lorsqu'elles sont installées : plusieurs services sont activés par défaut, et aucune politique de filtrage des connexions ou des paquets n'est activée par défaut. D'un autre côté, les administrateurs de ces systèmes peuvent se servir des scripts de Bastille Unix pour colmater les trous de sécurité. Bastille Unix peut être trouvé sur le site bastille-linux.sourceforge.net.

RedHat/CentOS est l'une des distributions les plus anciennes de Linux. Elle est populaire pour les serveurs parce qu'elle essaye d'être simple et sécuritaire. RedHat/CentOS est plus lent dans la publication de distributions incluant les dernières technologies.

Debian est une distribution de référence pour l'installation des serveurs. Dans ces distributions Debian inclut traditionnellement uniquement des logiciels « Open Source » sans extension propriétaire ou sans extension inhabituelle. Debian est aussi de loin la distribution la plus conservatrice, elle est donc la distribution la plus stable et sécuritaire disponible.

L'installation

La sécurité commence par l'installation. Les choix faits par l'administrateur lors de l'installation peuvent se répercuter plus tard en problème de sécurité. Dans cette section les principales étapes d'une installation sécuritaire sont présentées. Les étapes présentées, peuvent pour certaines distributions ne pas être présentées dans l'ordre correct. Elles devront être adaptées en fonction de la distribution et de la version.

Étape 1 : Installation depuis la source

La première étape d'une installation sécuritaire de Linux est de s'assurer de l'intégrité de votre source. Ne jamais installer Linux à partir de CD dont la provenance est douteuse. Il est même préférable d'acheter les CD d'installation de Linux d'un détaillant reconnu ou de télécharger Linux à partir des serveurs officiels. Voici une liste des sites officiels pour les principales distributions.

Distribution	Site
Red Hat	www.redhat.com
CentOS	www.centos.org
Ubuntu	www.ubuntu.com
Mint Linux	www.linuxmint.com
Mageia	www.mageia.org
Debian	www.debian.org

Étape 2 : Définition de partitions multiples

Il est beaucoup plus commode de créer une seule grande partition pour votre système de fichiers Linux que de créer plusieurs partitions. Cependant, les principaux avantages du point de vue de la sécurité sont :

- Éviter certaines attaques;
- Monter certaines partitions en exécution limitée;
- Monter certaines partitions avec SUID/SGID désactivé;
- Monter certaines partitions en lecture seule.

Une fois le design de l'installation terminé, la table de partition suivante devrait être obtenue :

Système de fichiers	Taille	Traitement spécial
/boot	100 Mo	Lecture seule.
/ (root)	500 Mo	lecture seule.
/tmp	500 Mo	Pas de SUID/SGID, pas d'exécution.
/usr	6 Go	Pas de SUID/SGID.
/home	Variable	Pas de SUID/SGID, pas d'exécution.

Les tailles de partitions proposées sont flexibles et dépendent de la taille de votre disque et de vos plans d'installation. Elles peuvent être ajustées en fonction des besoins de l'installation.

Étape 3 : Installation et activation de l'essentiel uniquement

Les distributions comme RedHat/CentOS ou Ubuntu ont automatisé leur processus d'installation faisant en sorte que l'administrateur a peu de contrôle sur les paquetages installés. La meilleure façon de faire l'installation est encore de choisir manuellement les paquetages à installer. Voici quelques lignes directrices pour aider au choix des paquetages :

- Ne pas installer les outils de développement (C, C++, ...);
- Ne pas installer Xfree86 sur les serveurs;
- Limiter le nombre de services installés. Les postes de travail n'ont pas besoin de httpd par exemple. Les routeur n'ont pas besoin de ftpd, de httpd ou de nfsd

Étape 4 : Réorganisation des systèmes de fichiers

Une fois l'installation terminée les mesures de sécurité liées aux multiples partitions doivent être mises en place. Pour effectuer les opérations suivantes l'ordinateur doit être redémarré en mode dépannage.

Tel que spécifié à l'étape de, la partition, root (/) sera en lecture seule. Cependant, les répertoires /var et /opt nécessitent la capacité d'écriture. Afin que Linux fonctionne correctement /var et /opt seront déplacés sur la partition /usr.

```
mkdir /usr/root-write
cp -dpR /var /opt /usr/root-write
rm -rf /var /opt
ln -s /usr/root-write/var /var
ln -s /usr/root-write/opt /opt
```

Il est également préférable de protéger les programmes exécutables qui se trouvent dans /usr/bin et /usr/sbin.

```
mkdir /sbin
cp -dpR /usr/sbin/* /sbin
```

```
rm -rf /usr/sbin  
ln -s /usr/bin /usr/sbin
```

Puisque la partition `/usr` sera monté à l'aide de l'option *nosuid* il faut aussi déplacer le serveur X dans le répertoire `/bin`.

```
cp /usr/X11R6/bin/Xfree86 /bin  
rm /usr/X11R6/bin/Xfree86  
ln -s /bin/Xfree86 /usr/X11R6/bin
```

Le fichier `/etc/fstab` sera modifié de façon à obtenir un fichier résultat semblable à celui-ci

```
# Système de fichiers Linux  
/dev/hda1  /      ext3    defaults        1 1  
/dev/hda2  /tmp   ext3    noexec, nosuid  1 2  
/dev/hda3  /boot  ext3    nosuid,ro       1 2  
/dev/hda5  /usr   ext3    nosuid          1 2  
/dev/hda6  /home  ext3    noexec          1 2
```

Le nouveau système pourra maintenant être redémarré afin de s'assurer de son bon fonctionnement. Pour activer la partition root (`/`) en lecture seule il faut taper la commande suivante :

```
mount -o remount, ro /
```

Étape 5 : Installation des mises à jour

Une fois que l'installation est terminée et que le fichier `/etc/fstab` ait été modifié, les mises à jour doivent être installées. Il s'agit sans doute de l'étape la plus importante pour une installation sécuritaire, puisque les mises à jour de sécurité existent parce que le système a déjà été piraté en utilisant une vulnérabilité.

Bastille Unix

Bastille Unix est un outil qui permet de simplifier et d'automatiser l'installation sécuritaire de Linux. Il s'agit en fait d'un ensemble de scripts, écrits en *perl* et destinés à renforcer la sécurité

de Linux. Initialement écrit pour RedHat, les dernières versions fonctionnent aussi pour d'autres distributions.

Installation

La version 2.x de Bastille est disponible en format RPM pour RedHat ou Mandrake. Pour l'installer il suffit de taper la commande :

```
rpm -ivh Bastille-3.2.1-0.1.noarch.rpm
```

Pour que Bastille fonctionne correctement, *perl-Tk* ou *perl-Curses* doivent être installés sur l'ordinateur. Pour installer per-Tk taper la commande suivante :

```
rpm -ivh perl-Tk-a.b-c.i386.rpm
```

Pour installer *perl-Curses* tapez la commande suivante :

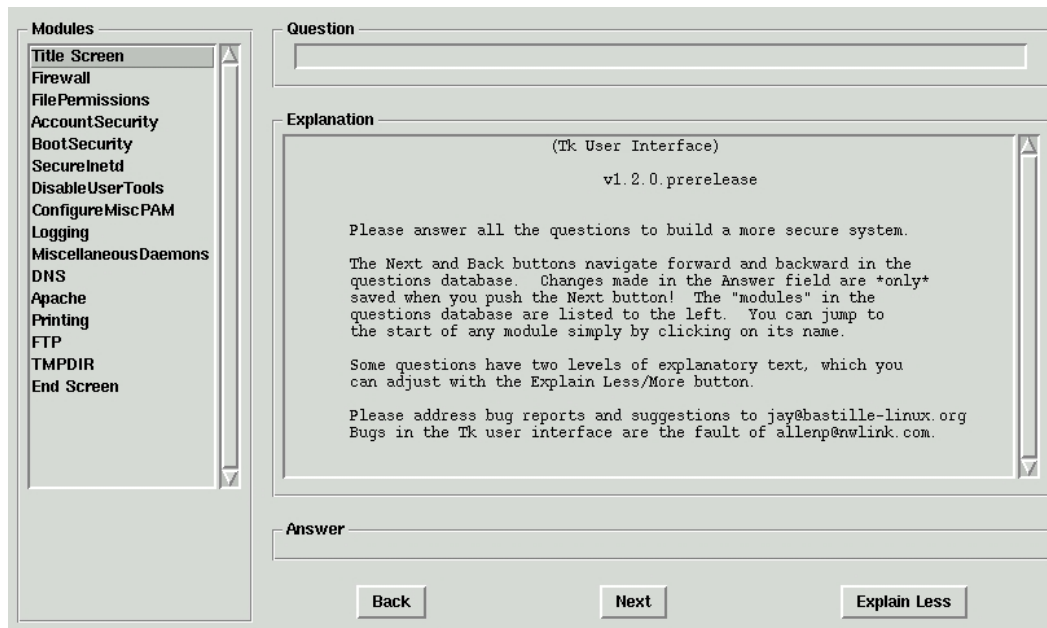
```
rpm -ivh perl-Curses-d.e-f.i386.rpm
```

Démarrage

Pour démarrer Bastille Linux il suffit de taper la commande suivante :

```
bastille -x
```

Si *perl-Tk* est installé, la fenêtre suivante apparaîtra au démarrage. Lorsque l'exécution de Bastille est terminée il faut redémarrer l'ordinateur pour que les modifications soient prise en compte.



Installation sécuritaire d'un serveur Windows

Cette section présente les principales étapes à réaliser pour sécuriser un serveur Windows.

Mot de passe de l'administrateur

La qualité du mot de passe de l'administrateur est importante pour la sécurité du réseau. Trois règles sont proposées :

1. Utilisez au moins 9 caractères
2. Mettez au moins un caractère de ponctuation dans les 7 premiers caractères
3. Mettez au moins 3 chiffres

Services inutiles

Après l'installation de Windows, il est important de désactiver tous les services qui ne sont pas nécessaire à la fonction du serveur.

Il faut éviter l'installation de tout logiciel qui ne sont pas absolument nécessaire à l'activité du serveur (ex : Client e-mail, Logiciel de bureautique, ...).

Comptes usagers

Une vérification de l'ensemble des comptes usagers du système à est nécessaire. Ainsi les comptes qui ne sont plus nécessaire doivent être désactivé ou supprimé. Si le compte invité est activé, désactivé le.

Fichiers et répertoires systèmes

Les ACL du système de fichier NTFS, permettent de restreindre de façon très précise les actions que pourront effectuer les utilisateurs sur les fichiers et les répertoires. Il est donc recommander de s'assurer que les fichiers importants de Windows aient des droits d'accès adéquat.

Visibilité sur le réseau

Afin d'éviter à des employés de parcourir le réseau à l'aide du *Voisinage réseau*, il est possible de retirer la présence du contrôleur de domaine.

Partages de fichiers

Les partages inutiles doivent être supprimer parce qu'il sont souvent utilisé comme porte d'accès lors d'intrusion sur un système. Il est aussi nécessaire de définir des autorisations appropriées sur tous les partages de fichiers.

Pour une sécurité maximale, il est possible de désactiver la création des partages administratifs à l'aide de la clé de registre suivante:

Logiciel anti-virus

Il est impératif d'installer un logiciel Anti-virus avec les dernières mises à jour en date.

Mise à jour

Chaque service pack pour Windows inclus toutes les mises à jour de sécurité des service pack antérieurs. Il est recommandé de maintenir à jour les versions des services pack sur les serveurs Windows. Le dernier service pack peut être télécharger sur le site de Microsoft.

Références

Aron Hsiao, « Sécurité sous Linux », Campus press, 2001.

CDAC, « Hardening Windows Server 2008 », 2010.

NSA, « Hardening Tips for default installation RH5 ».